

Pôr o AYContabilidade em produção

Este documento é o caminho completo, do zero à primeira empresa a trabalhar.

O que aqui está escrito é o mínimo, não o recomendado. As partes que a aplicação consegue impor sozinha já as impõe: se alguma das definições perigosas ficar como em desenvolvimento, o backend **recusa arrancar** e diz qual é. O que a aplicação não consegue verificar — as cópias de segurança, o certificado, quem tem acesso à máquina — fica por sua conta.

1. O que muda entre desenvolvimento e produção

	Desenvolvimento	Produção
AMBIENTE	dev	producao
Documentação da API (/docs)	aberta	fechada
SQL nos registos	escrito	silencioso
CORS	http://localhost:3000	o domínio público, em https
TOTP_CHAVE_CIFRA	opcional	obrigatória
Base de dados	exposta em 5432	só na rede interna
Dados de demonstração	criar_demo.py	recusa-se a correr
Primeira conta	super@plataforma.ao / demo12345	criar_superadmin.py , sem valores por omissão
Frontend	next dev	next build + node server.js
Cabeçalhos de segurança	desligados	HSTS, X-Frame-Options, nosniff

Os dois docker-compose são ficheiros **separados** de propósito. Um ficheiro único com condições lá dentro acaba sempre por ser copiado com a condição mal resolvida.

2. Antes de começar

Precisa de:

- **PostgreSQL 18** com uma base vazia e um utilizador só para ela;
- um **domínio** e um **certificado TLS** (Let's Encrypt serve);
- um **proxy à frente** — nginx, Caddy, ou o balanceador do fornecedor — que

termine o TLS e encaminhe para o backend e para o frontend. A aplicação não faz TLS e recusa arrancar com CORS em http:// para isto não passar despercebido;

- uma **chave da OpenAI**, se quiser o assistente. Sem ela, tudo o resto

funciona e o diagnóstico continua a correr — é local.

3. Segredos

Gere **cada um** com o seu próprio comando. Nunca reutilize entre ambientes, e nunca copie o `.env` de desenvolvimento.

```
python -c "import secrets; print(secrets.token_urlsafe(48))"
```

São dois, e servem para coisas diferentes:

- `JWT_SECRET_KEY` assina as sessões. Rodá-la expulsa toda a gente e é uma operação normal.
- `TOTP_CHAVE_CIFRA` cifra os segredos de segundo factor guardados na base.

Guarde-a fora da máquina. Se se perder, todas as contas com 2FA têm de o reconfigurar — e como as contas de plataforma exigem 2FA, ficaria sem operador.

São variáveis separadas de propósito: derivar a segunda da primeira faria uma rotação de rotina trancar toda a gente fora do 2FA sem aviso.

4. Backend

```
cd Producao/backend
cp .env.producao.example .env
```

Preencha o `.env`. Depois:

```
python -m pip install -r requirements.txt
alembic upgrade head
python scripts/criar_superuser.py
```

O `alembic upgrade head` cria o esquema e semeia o registo de modelos de IA com `gpt-4.1`, `gpt-4.1-mini` e `gpt-4o-mini`. O `criar_superuser.py` pede nome, e-mail e palavra-passe na consola — não aceita a palavra-passe por argumento, porque o que passa num argumento fica no histórico da shell e na lista de processos.

A correr:

```
python -m uvicorn main:app --host 0.0.0.0 --port 8001 --no-proxy-headers --workers 2
```

`--no-proxy-headers` **não é opcional**. Sem ele, o uvicorn reescreve a origem do pedido a partir do `X-Forwarded-For` antes de a aplicação a ver — e qualquer cliente forja esse cabeçalho. Quem decide em que proxies se confia é a variável `PROXIES_CONFIAVEIS`; sem a flag, essa decisão não chega a ter efeito.

5. Frontend

```
cd Producao/frontend
cp .env.producao.example .env.production.local
```

Preencha os dois endereços. **Entram no build, não no arranque** — mudá-los depois obriga a construir outra vez.

`NEXT_PUBLIC_SITE_URL` não é decorativo: sem ele, a etiqueta canónica da página de apresentação aponta para `localhost` e os motores de busca descartam-na.

```
npm ci
npm run build
node .next/standalone/server.js
```

6. Com Docker

```
cp Producao/backend/.env.producao.example Producao/backend/.env
```

Na raiz, um `.env` com o que o compose precisa:

```
POSTGRES_USER=aycontab
POSTGRES_PASSWORD=<gerada>
POSTGRES_DB=aycontabilidade
NEXT_PUBLIC_API_URL=https://api.oseudominio.ao
NEXT_PUBLIC_SITE_URL=https://www.oseudominio.ao
```

```
docker compose up -d --build
docker compose exec backend alembic upgrade head
docker compose exec backend python scripts/criar_superadmin.py
```

Os dois serviços ficam em `127.0.0.1:8001` e `127.0.0.1:3000` — só o proxy lhes chega. A base não expõe porta nenhuma.

Para desenvolvimento: `docker compose -f docker-compose.dev.yml up -d`.

7. O proxy

O mínimo, com Caddy:

```
api.oseudominio.ao {  
    reverse_proxy 127.0.0.1:8001  
}  
  
www.oseudominio.ao {  
    reverse_proxy 127.0.0.1:3000  
}
```

Se puser um proxy, acrescente o endereço dele a `PROXIES_CONFIAVEIS` no `.env` do backend. Sem isso, o IP que fica na auditoria é o do proxy e não o de quem fez o pedido.

8. Primeira entrada

1. Abra `https://www.oseudominio.ao` — deve ver a página de apresentação.

2. **Entrar**, com o e-mail e a palavra-passe que definiu. Deixe o campo da

empresa vazio: a conta de plataforma não pertence a nenhuma.

1. Vá a **Perfil** e **active o segundo factor**. A área de administração fica fechada até o fazer — é obrigatório para esta conta.

1. **Plataforma** → **Configurações**: confirme o modelo de IA e os preços contra a facturação real da OpenAI.

1. **Plataforma** → **Licenças**: gere a primeira licença. A chave é mostrada ****uma única vez**** — a base guarda só o resumo criptográfico dela.

1. Entregue a chave ao cliente. Ele activa-a em `/activar` e a empresa nasce com o plano de contas em PGC-AR feito.

9. Antes de considerar isto fechado

O que a aplicação **já garante** sozinha:

- não arranca em produção com CORS local, sem TLS, sem `TOTP_CHAVE_CIFRA` ou com uma `JWT_SECRET_KEY` curta;
- não deixa correr o seed de demonstração;
- fecha a documentação da API;
- não escreve SQL nos registos;
- não corre como `root` dentro do contentor.

O que **fica por sua conta**:

- [] **Cópias de segurança da base, testadas.** Uma cópia que nunca foi restaurada não é uma cópia. `pg_dump` diário, e uma restauração de ensaio.
- [] **A `TOTP_CHAVE_CIFRA` guardada fora da máquina.**
- [] **Certificado TLS com renovação automática.**
- [] **Quem tem acesso SSH à máquina** — é quem tem acesso a tudo.
- [] **Rotação da chave da OpenAI** se alguma vez tocou num ficheiro

versionado (ver `docs/PENDENTES.md`).

- [] **Preencher os dados institucionais** em

`Producao/frontend/src/lib/institucional.ts`, que aparecem no rodapé da página pública. Estão vazios de propósito.

E leia `docs/FIDELIDADE_AO_PILOTO.md` antes de decidir a data: as regras de negócio estão fiéis ao Piloto, mas há funcionalidades que ainda não foram migradas — a mais importante é a integração de lançamentos diferidos.

10. Actualizar uma instalação a correr

```
git pull
docker compose build
docker compose up -d
docker compose exec backend alembic upgrade head
```

As migrações correm **depois** de a imagem nova estar de pé, e são cumulativas. Nunca edite uma migração já aplicada: crie outra.